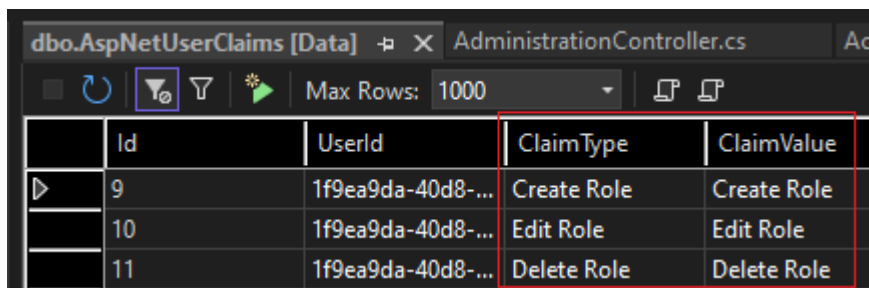


98 - Claim type and claim value in claims policy based authorization

dbo.AspNetUserClaims table:



	Id	UserId	ClaimType	ClaimValue
▶	9	1f9ea9da-40d8-...	Create Role	Create Role
	10	1f9ea9da-40d8-...	Edit Role	Edit Role
	11	1f9ea9da-40d8-...	Delete Role	Delete Role

Където в случая ClaimType съвпада с ClaimValue.

Only Claim Type in Authorization Policy

To satisfy this policy **Edit Role** claim must be present

```
services.AddAuthorization(options =>
{
    options.AddPolicy("EditRolePolicy",
        policy => policy.RequireClaim("Edit Role"));
});
```



Само проверяваме ClaimType, без ClaimValue. Това е достатъчно.

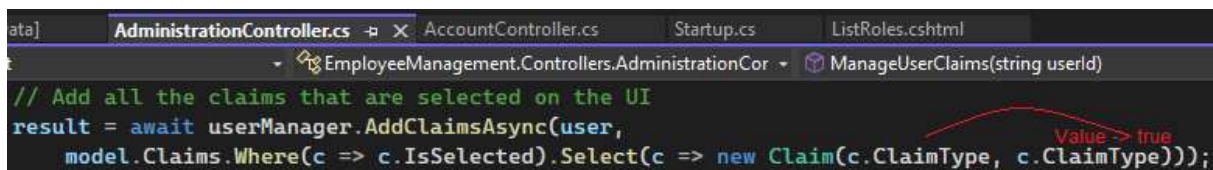
Claim Type and Claim Value

To satisfy this policy **Edit Role** claim must be present with a value of **true**

```
services.AddAuthorization(options =>
{
    options.AddPolicy("EditRolePolicy",
        policy => policy.RequireClaim("Edit Role", "true"));
});
```



За да се удовлетвори условието, за ClaimValue се задава стойност true.



```
// Add all the claims that are selected on the UI
result = await userManager.AddClaimsAsync(user,
    model.Claims.Where(c => c.IsSelected).Select(c => new Claim(c.ClaimType, c.ClaimType)));
```

На този етап, вместо (ClaimType, ClaimValue), използваме на 2 места ClaimType. Искаме да зададем стойност bool value, така че при маркиране на check-box, да имаме true, иначе false.

```
model.Claims.Select(c => new Claim(c.ClaimType, c.IsSelected ? "true" : "false"));
```

```
model.Claims.Select(c => new Claim(c.ClaimType, c.IsSelected ? "true" : "false")));
```

Administration/EditUser/87cabcf7-6319-4672-a7c8-db5a048fa5f7

Маркираме Create, Edit, без Delete -> Update:

Manage User Claims

☒ Create Role
☒ Edit Role
☐ Delete Role

true

true

false

Update

Cancel

User Claims

true

true

false

Manage Claims

UserId	ClaimType	ClaimValue
1f9ea9da-40d8-...	Create Role	Create Role
1f9ea9da-40d8-...	Edit Role	Edit Role
1f9ea9da-40d8-...	Delete Role	Delete Role
a5b9400f-45cf-...	Create Role	Create Role
a5b9400f-45cf-...	Edit Role	Edit Role
b2056455-c2b4-...	Delete Role	Delete Role
87cabcf7-6319-...	Create Role	true
87cabcf7-6319-...	Edit Role	true
87cabcf7-6319-...	Delete Role	false
NULL	NULL	NULL

В таблицата са се смесили стари и нови стойности. Старите ще коригираме през UI.

Трябва обаче да коригираме в Administration/EditUser

[Data]
AdministrationController.cs*
AccountController.cs
Startup.cs
ListRoles.cshtml

ent
EmployeeManagement.Controllers.AdministrationCor
EditUser(string id)

Claims = userClaims.Select(c => c.Type + " : " + c.Value).ToList(),

досега е имало само c.Value, а ние добавяме c.Type + разграничител при изписването. Така виждаме и двете:

User Claims

Create Role : true
Edit Role : true
Delete Role : false

Manage Claims

Manage User Claims

☒ Create Role
☒ Edit Role
☒ Delete Role

true

true

false

Update

Cancel

Виждаме, че има малък бър:Delete role: false, а като се отвори съответния view, чек-боксът е маркиран, което се дължи на съответния GET:

Само от проверка на ClaimType -> isSelected = true.

EmployeeManagement.Controllers.AdministrationCor
ManageUserClaims(string userId)

if (existingUserClaims.Any(c => c.Type == claim.Type && c.Value == "true"))
{
 userClaim.IsSelected = true;
}

Затова добавяме изискването и Value да бъде true.

Сега автоматично чек-боксът е вече празен.

Обновяваме даните за всички потребители през UI, за да се актуализират стойностите в БД.

```
services.AddAuthorization(options =>
{
    options.AddPolicy("DeleteRolePolicy",
        policy => policy.RequireClaim("Delete Role"));

    options.AddPolicy("EditRolePolicy", (ClaimType, ClaimValue)
        policy => policy.RequireClaim("Edit Role", "true"));
        // key comparishing: (unsensitive, SENSITIVE)
    options.AddPolicy("AdminRolePolicy",
        policy => policy.RequireRole("Admin"));
});
```

Интересното в случая е следното: когато даден потребител има права само за Delete Role, се вижда само Delete btn, но ако има (само) Edit Role, се виждат и Edit + Delete. Така е и на видеото. Явно е някаква вградено автоматично разпознаване edit да включва delete? Чудно. Нали са CRUD операции, би трябвало да са разграничени.

```
troller.cs  ListRoles.cshtml*  Startup.cs
<form asp-action="DeleteRole" asp-route-id="@role.Id" method="post">
    @if ((await authorizationService.AuthorizeAsync(User, "EditRolePolicy")).Succeeded)
    {
        <a asp-controller="Administration" asp-action="EditRole"
            asp-route-id="@role.Id" class="btn btn-primary">
            Edit
        </a>
    }

    @if ((await authorizationService.AuthorizeAsync(User, "DeleteRolePolicy")).Succeeded)
    {
        <span id="deleteSpan_@role.Id">
            <a href="#" class="btn btn-danger"
                onclick="confirmDelete('@role.Id', true)">Delete</a>
        </span>

        <span id="confirmDeleteSpan_@role.Id" style="display:none">
            <span>Are you sure you want to delete?</span>
            <button type="submit" class="btn btn-danger">Yes</button>
            <a href="#" class="btn btn-primary"
                onclick="confirmDelete('@role.Id', false)">No</a>
        </span>
    }
</form>
```

Claim Type and Claim Value

To satisfy this policy **Country** claim must be present with a value of **USA, India or UK**

```
services.AddAuthorization(options =>
{
    options.AddPolicy("AllowedCountryPolicy", ( CType, CValue1, CV2, SV3)
        policy => policy.RequireClaim("Country", "USA", "India", "UK"));
});
```

string

➤ **ClaimType** comparison is case in-sensitive

➤ **ClaimValue** comparison is case sensitive

```
options.AddPolicy("EditRolePolicy", ( CType, strings)
    policy => policy.RequireClaim("Edit Role", "true"));

options.AddPolicy("AdminRolePolicy",
    policy => policy.RequireRole("Admin"));

(parameter) params string[] allowedValues
Values the claim must process one or more of for evaluation to succeed.
```

ClaimValue може да бъде лист от стрингове, като задължително трябва да се избере 1 от тях.